THREAT MODELING

SECURE WEB DEVELOPMENT

DEFINITIONS

THREAT MODELING
IN SDLC

PERFORMING
THREAT MODELING

DEFINITIONS

Threats

- Recall: A threat is what can go wrong because of the exploit of the vulnerabilities or attack on the assets, such as data theft or unauthorized modification of the data.
- Potential or actual undesirable event that may be malicious or incidental
  - Malicious → DoS attack
  - Incidental → failure of a storage device

Threat Model

- A structured representation of all the information that affects the security of an application
- A view of the application and its environment through security glasses

Threat Modeling

- A process for capturing, organizing, and analyzing information that affects the security of an application
- Enables informed decision-making about application security risk
- In addition to producing a model, typical threat modeling efforts also produce a prioritized list of security improvements to the concept, requirements, design, or implementation

Attacker's PoV

Flexible

Early in the SDLC

Pros

Cons

New technique

Good threat model does not mean good software

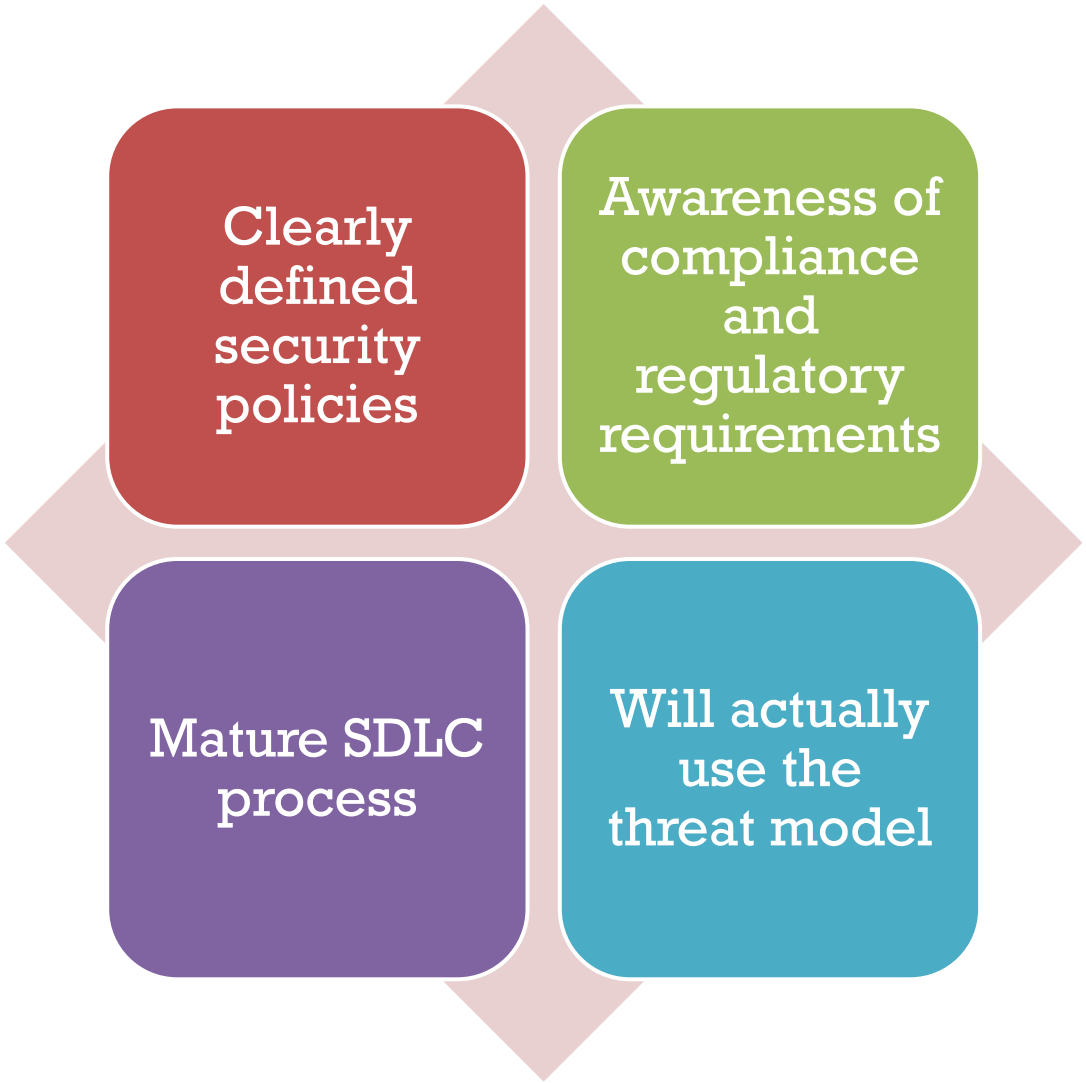
Objectives of Threat Modeling

- A procedure for optimizing Network/ Application/Internet Security by identifying objectives and vulnerabilities
- Defining countermeasures to prevent, or mitigate the effects of, threats to the system

Benefits of Threat Modeling

- Provides a clear "line of sight" across a project that justifies security efforts
- Allows security decisions to be made rationally
- Produces an assurance argument that can be used to explain and defend the security of an application
  - An assurance argument starts with a few high-level claims, and justifies them with either subclaims or evidence

Requirements



THREAT MODELING IN SDLC

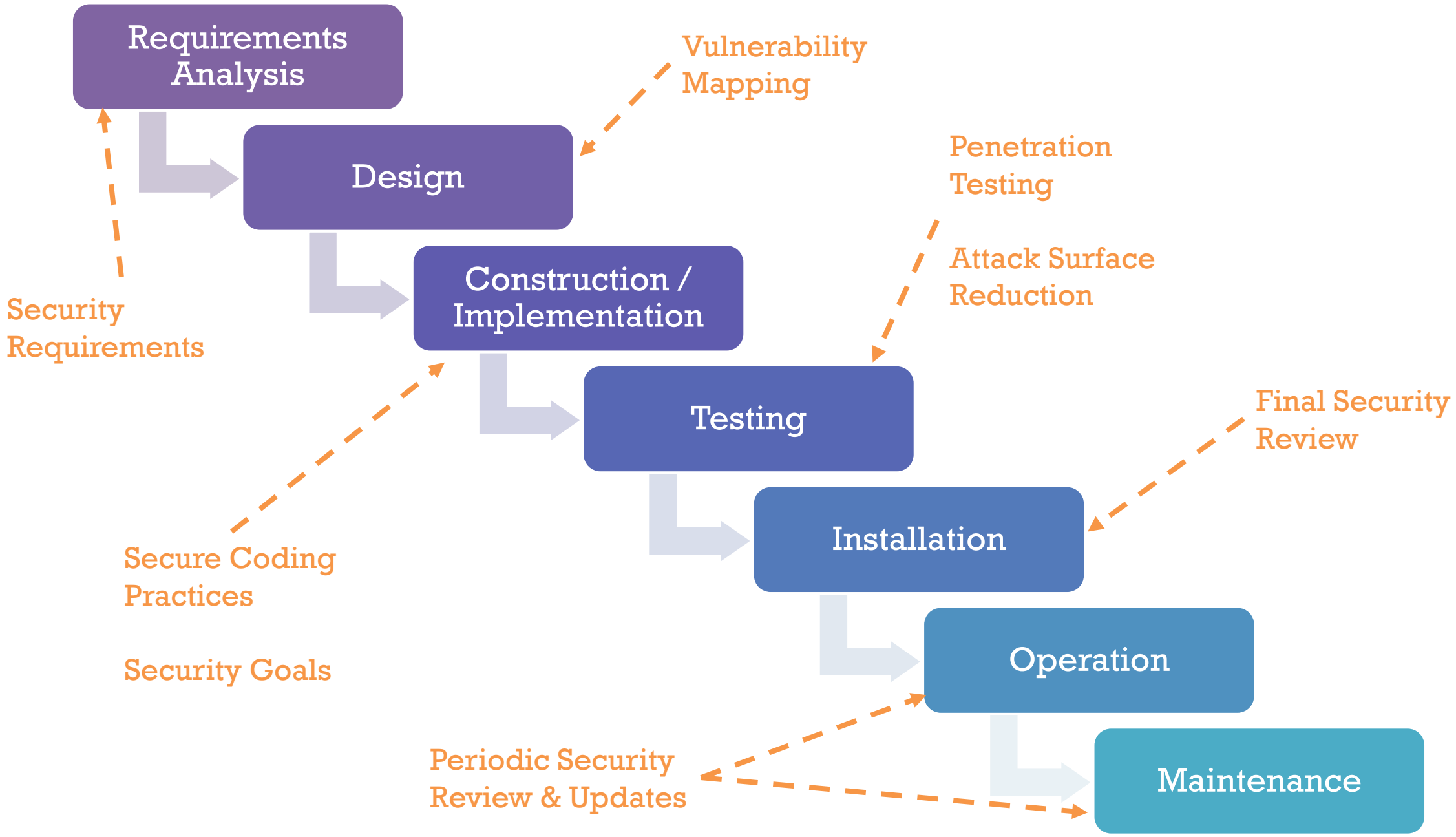
Threat Modeling in SDLC

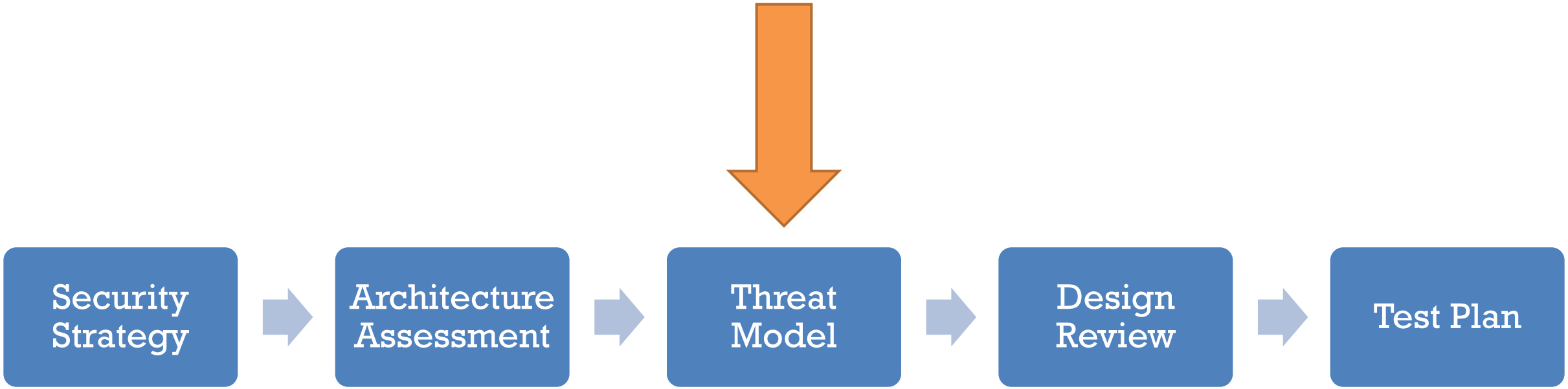
Best applied continuously throughout a software development project

Essentially the same at different levels of abstraction, although the information gets more and more granular throughout the life cycle

Threat Modeling in SDLC

- A high-level threat model should be defined in the concept or planning phase and then refined throughout the life cycle
- As more details are added to the system, new attack vectors are created and exposed
  - Ongoing threat modeling process should examine, diagnose, and address these threats


Requirements Analysis
Design
Construction / Implementation
Testing
Installation
Operation
Maintenance
Vulnerability Mapping
Penetration Testing
Attack Surface Reduction
Final Security Review
Security Requirements
Secure Coding Practices
Security Goals
Periodic Security Review & Updates


Security Strategy
Architecture Assessment
Threat Model
Design Review
Test Plan

PERFORMING THREAT MODELING

Define

1. Identify security objectives and assets
2. Profile the application

Model

3. Decompose the application
4. Identify threats and vulnerabilities

Measure

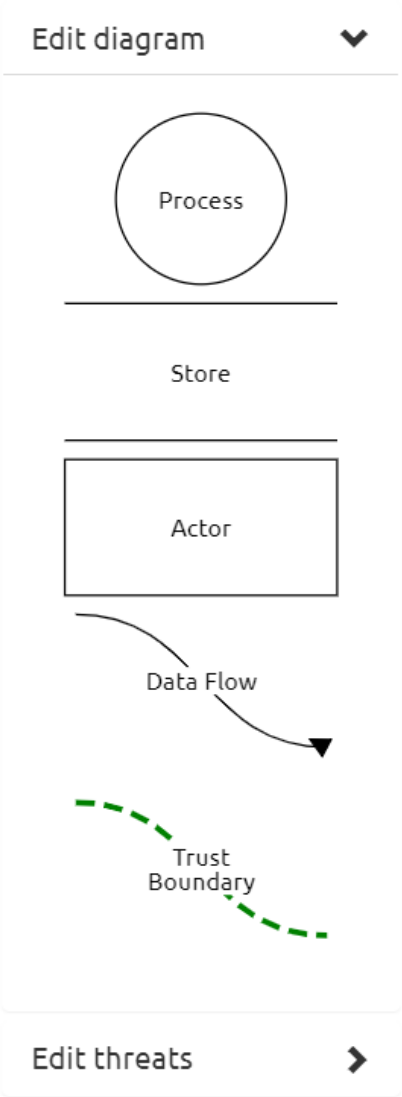
5. Document the threats
6. Prioritize the threats

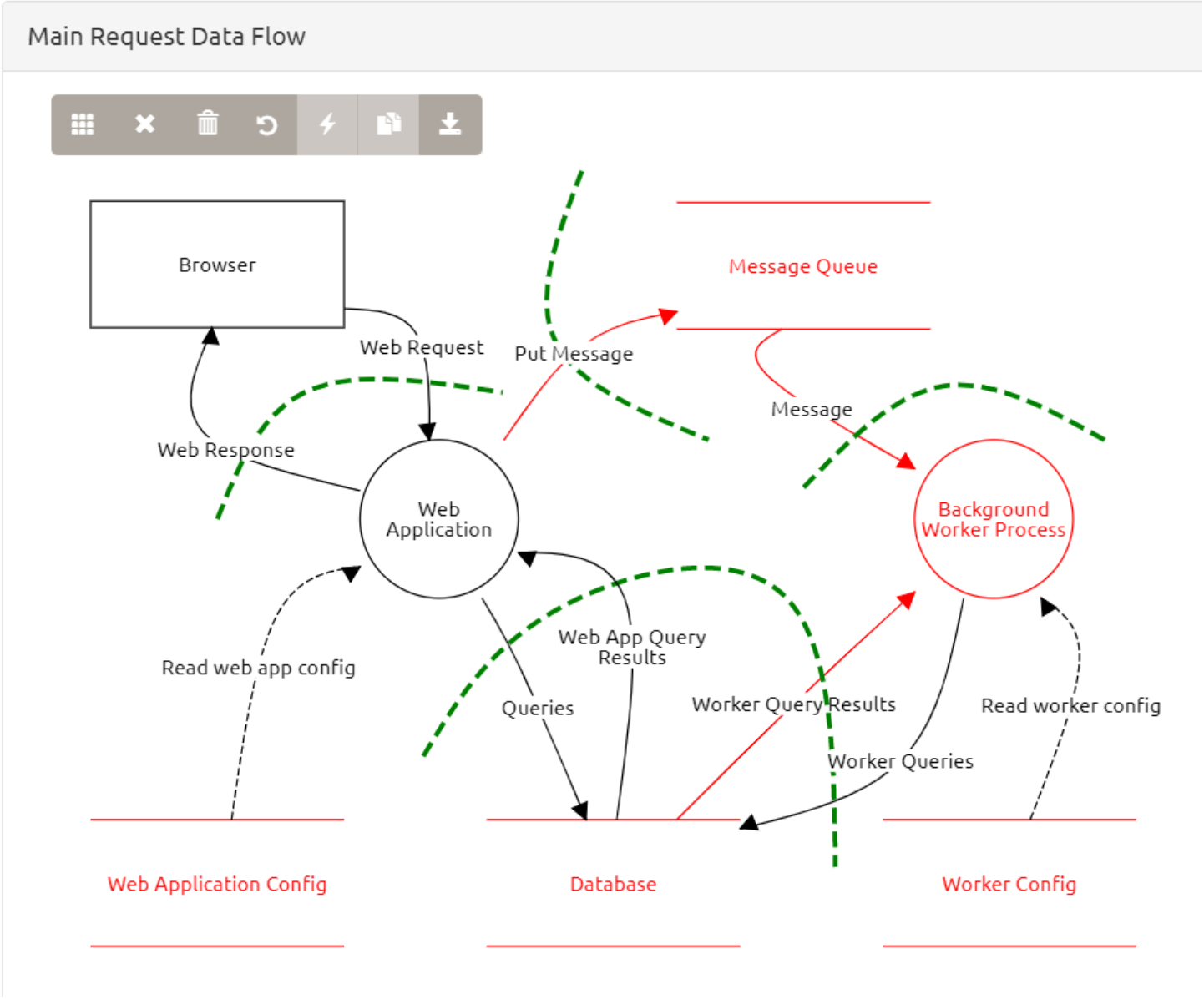
Identify Security Objectives and Assets

- Prior to any action, the overall direction of an organization in terms of security should be understood
- Ideally, this should be performed by business leadership, development team, and the QA team

Profile the Application

- Provides a high-level view of the application and its components
- Achieved through the analysis of an application's architecture and design documents
- The following artifacts may help:
  - Class Diagrams
  - ERD Diagrams
  - Data Flow Diagrams
  - Use Case Diagrams


Edit diagram
Process
Store
Actor
Data Flow
Trust Boundary
Edit threats


Main Request Data Flow
Browser
Message Queue
Web Request
Put Message
Message
Web Response
Web Application
Background Worker Process
Read web app config
Web App Query Results
Queries
Worker Query Results
Read worker config
Worker Queries
Web Application Config
Database
Worker Config

Profile the Application

Physical Topology	Logical Topology	Components, services, protocols	Actors
Data Elements	Access control matrix	Technologies	External dependencies

Decompose the Application

- From the top, drill down to specific components for analysis
- Identify features, behaviors, and requirements that can impact security given how the application functions

Decompose the Application

Identify Trust Boundaries

Identify Entry Points

Identify Exit Points

Identify Data Flow

Identify Privileged Code

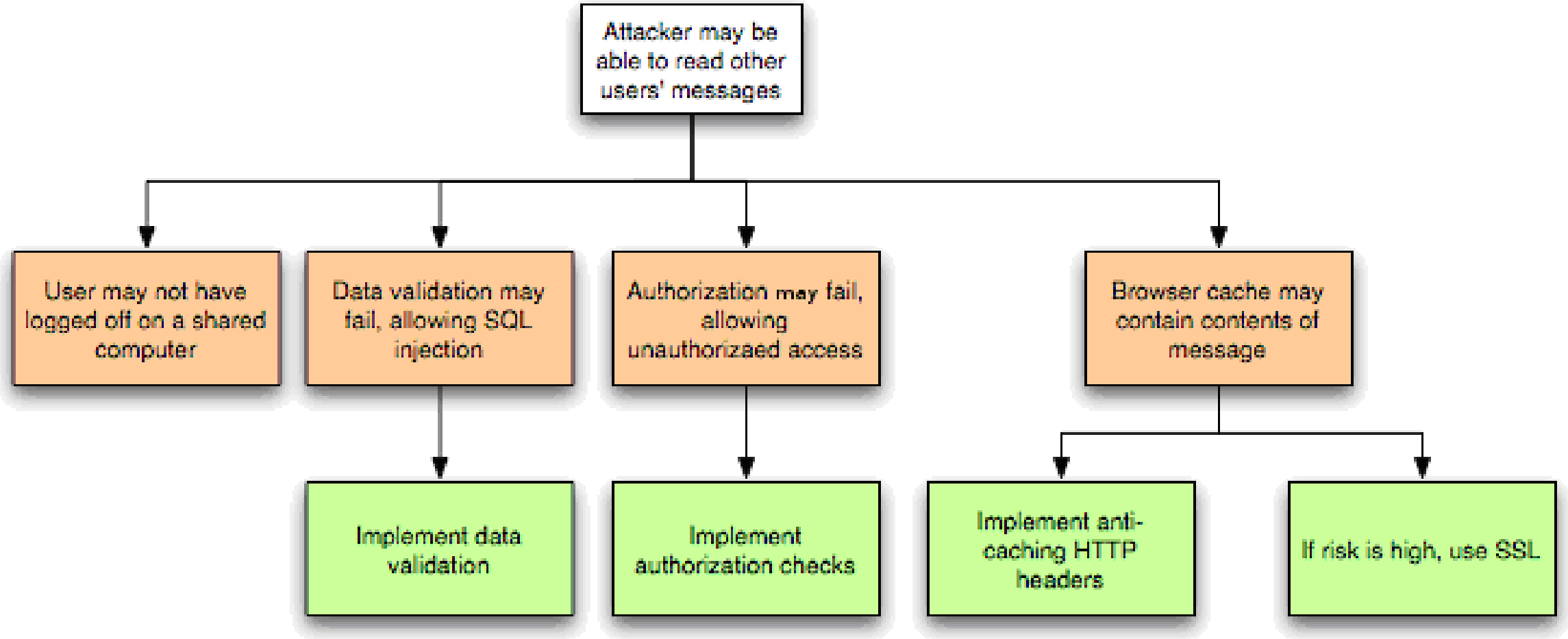
Document Security Profile

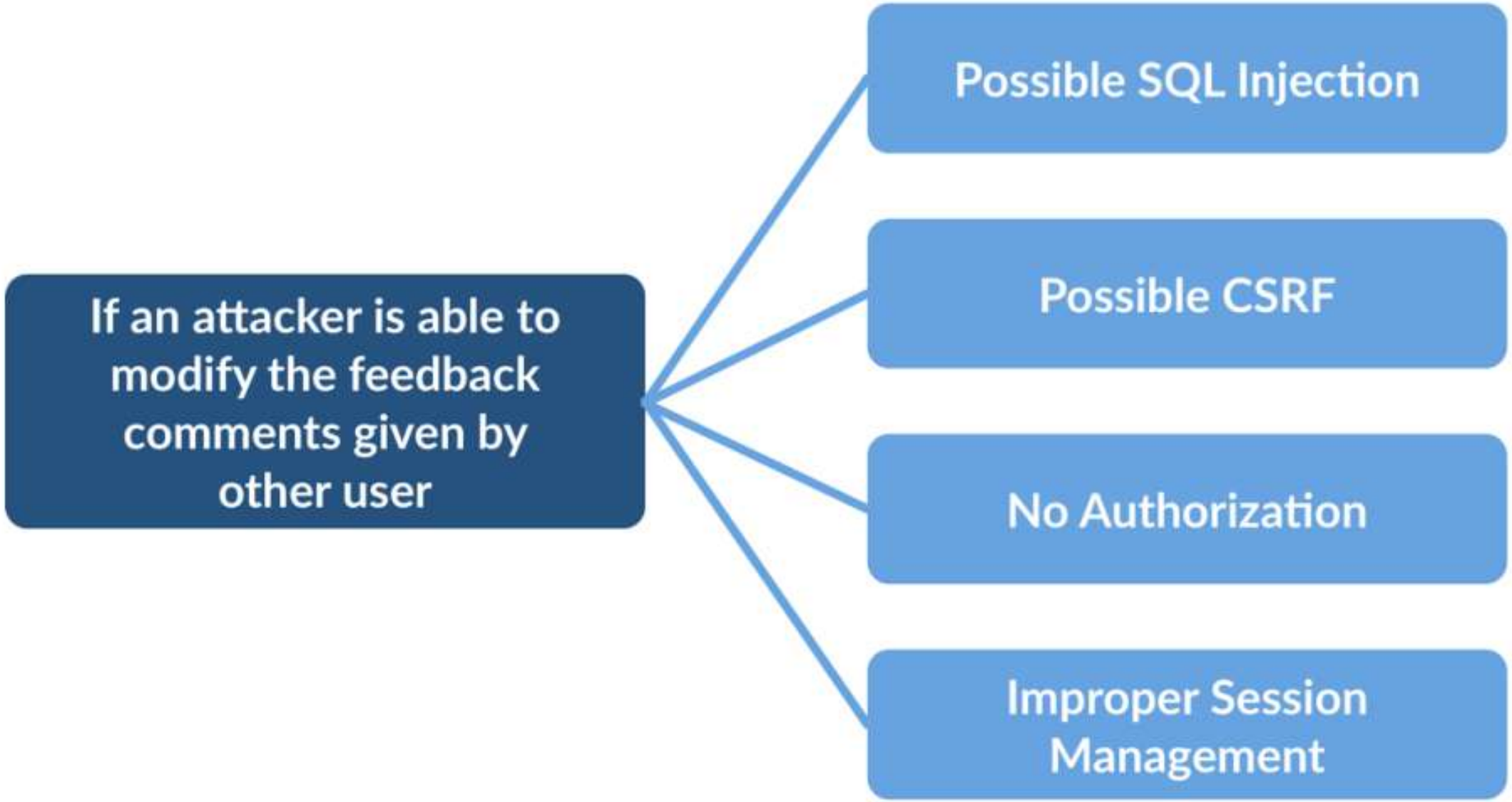
Identify Threats and Vulnerabilities

- Once a thorough understanding of the application is achieved, specific threats to the application should be identified
- Focus should be on known threats
- Tracking threats:
  - Threat Graph
  - Structured Threat List

Threat Graph

- Places developers in the mindset of an attacker
- Brainstorming possible threat scenarios
- Represented as a tree:
  - Root – attacker's objective/attack type
  - Child Node – vulnerability
  - *Bottom Node – security control*
- References
  - OWASP Top 10
  - Sans Top 25


Attacker may be able to read other users' messages
User may not have logged off on a shared computer
Data validation may fail, allowing SQL injection
Authorization may fail, allowing unauthorizaed access
Browser cache may contain contents of message
Implement data validation
Implement authorization checks
Implement anti-caching HTTP headers
If risk is high, use SSL


If an attacker is able to modify the feedback comments given by other user
Possible SQL Injection
Possible CSRF
No Authorization
Improper Session Management

Threat List

- Goal based approach to threat modeling
- More structured than the threat graph
- Can show cross-correlation between different threats
- Possible with:
  - STRIDE
  - OCTAVE
  - NSA IAM

Identify Threats and Vulnerabilities

- Common threats:
  - Ignorant User
  - Accidental Discoverer
  - Curious Attacker
  - Script Kiddies
  - Insider
  - Organized Crime
- STRIDE may be used to classify threats based on intent

	Threat	Property Violated	Threat Definition
S	Spoofing identify	Authentication	Pretending to be something or someone other than yourself
T	Tampering with data	Integrity	Modifying something on disk, network, memory, or elsewhere
R	Repudiation	Non-repudiation	Claiming that you didn't do something or were not responsible; can be honest or false
I	Information disclosure	Confidentiality	Providing information to someone not authorized to access it
D	Denial of service	Availability	Exhausting resources needed to provide service
E	Elevation of privilege	Authorization	Allowing someone to do something they are not authorized to do

STRIDE

Document the Threats

- All outputs from the previous steps should be recorded due to the iterative nature of threat modeling
- Diagram vs. Text
- A standard template should be used to ensure consistency
  - Threat Identifier
  - Description
  - Targets
  - Attack Techniques
  - Impact
  - Risk

Prioritize the Threats

- Threat modeling is meant to assist in decision making
- Prioritizing the threats identified helps development teams identify and rank which to tackle first
- Common Approaches:
  - Rank Risks: Notice, Low, Medium, High, etc.

Prioritize the Threats

- Threat modeling is meant to assist in decision making
- Prioritizing the threats identifies helps development teams identify and rank which to tackle first
- Common Approaches:
  - Process for Attack Simulation and Threat Analysis (PASTA)

$$Risk = \frac{(Threat \times Vulnerability \times Probability \times Impact)}{Countermeasures}$$

Prioritize the Threats

- Threat modeling is meant to assist in decision making
- Prioritizing the threats identifies helps development teams identify and rank which to tackle first
- Common Approaches:
  - Damage, Reproducibility, Exploitability, Affected Users, Discoverability (DREAD)

$$Risk = Probability \times Impact$$

$$Probability = Reproducibility + Exploitability + Discoverability$$

$$Impact = Damage + Affected\ Users$$

DREAD Sample Computation

	Probability of Occurrence (P)			Business Impact (I)		P	I	Risk (PxI)
	Reproducibility	Exploitability	Discoverability	Damage Potential	Affected Users			
SQL Injection	3	2	2	3	3	7	6	42
XSS	3	3	3	3	3	9	6	54
Cookie Replay	2	2	2	3	1	6	4	24
Session Hijacking	2	2	3	1	1	7	3	21

THREAT MODELING

SECURE WEB DEVELOPMENT